

WALL MANAGEMENT SYSTEM

Production & Compliance Specification

Full feature lifecycles · production-grade engineering · security · DPDP Act 2023 & Rules 2025 · GST, IT Act, RBI, consumer-protection and IP compliance

Document: AWL/ENG/2026/WMS-SPEC-001

Companion to: AWL/PRODUCT/2026/WMS-001 (Feature Plan) · AWL/ENG/2026/WMS-AUDIT-001 (Audit Pack)

Scope: 32 launch features across 6 pillars

Data role: Artwall Labs Pvt Ltd = Data Fiduciary under the DPDP Act, 2023

Version: 1.0 · August 2026

Classification: Internal — Engineering, Legal & Compliance

This specification treats each feature as a system with a defined lifecycle — states, actors, rules, data touched, events and failure modes — then wraps the whole product in the production and regulatory controls required to operate it lawfully at scale in India.

CONTENTS

1 How to read this document

2 Feature lifecycles — 32 launch features

Pillar 1 · Slot Management (F01–F12)

Pillar 2 · Exhibition Operations (F13–F16)

Pillar 3 · Payments & Billing (F17–F20)

Pillar 4 · Visitor & Analytics (F21–F26)

Pillar 5 · Discovery & Engagement (F27–F30)

Pillar 6 · Artist Management (F31–F32)

3 Production-grade engineering

Environments, CI/CD, reliability, observability, testing

4 Security engineering & threat model

5 DPDP Act 2023 & Rules 2025 compliance

Roles, consent, notice, rights, retention, breach, children, SDF

6 Other regulatory compliance

GST · IT Act & e-sign · RBI/payments · consumer protection · IP · accessibility

7 Feature × compliance traceability

8 Data retention & lifecycle schedule

SECTION 1

How to read this document

Every feature below is specified as a small state machine rather than a screenshot. The intent is that an engineer can implement it, a reviewer can audit it, and legal can confirm it processes personal data lawfully — from one block.

Each feature block carries:

- **Lifecycle** — the ordered states the entity moves through, and who/what triggers each move.
- **Rules** — the invariants the system enforces (referencing the plan WMS-001 and audit WMS-AUDIT-001 where relevant).
- **Data & PII** — the tables touched and whether personal data is involved (the trigger for DPDP obligations in Section 5).
- **Events** — domain events emitted, which drive async work (email, webhook, socket, chain).
- **Edge / failure** — the non-happy paths that must be handled for the feature to be production-grade.
- **Compliance** — appears only where the feature touches a regulated activity (personal data, payments, tax, IP).

Legend for lifecycle arrows: A → B is a permitted transition; a bracketed actor [admin] shows who may trigger it. Terminal states have no outgoing arrow.

SECTION 2

Feature Lifecycles

Thirty-two launch features, grouped by the six pillars of WMS-001. Ordering and numbering follow the plan's feature index.

Pillar 1 · Slot Management

F01 Dynamic slot grid configuration		Admin · route POST /wall/resize
<i>The wall is not a fixed grid — admins define how many slots exist and how they are laid out.</i>		
ACTORS	Admin (owner), System (validation)	
LIFECYCLE	draft grid → [admin] validate (no overlaps, sane bounds) → publish → active → [admin] re-config → re-validate → re-publish	
RULES	Slot count is admin-set, not hard-coded (ref WMS-001 §1.1). A re-config may not orphan a live booking: slots in state live/installed/booked are locked and carried across configs. Templates ('28-slot standard') are saved layouts.	
DATA & PII	slots, grid_config. No personal data.	
EVENTS	grid.reconfigured → invalidates availability cache, re-renders live wall.	
EDGE / FAILURE	Reducing the grid below the count of occupied slots is rejected; concurrent edits guarded by version/optimistic lock.	

F02 Visual slot map editor (drag-and-drop)		Admin · route POST /wall/reorder
<i>A physical-layout editor: drag a slot to reposition it, click to configure size/type/status.</i>		
ACTORS	Admin	
LIFECYCLE	select slot → drag → drop on target → [system] swap grid coordinates atomically → persist	
RULES	Drag swaps two slots' coordinates in a single transaction so no two slots ever share a cell. Editing is disabled for terminal/locked slots. Every move writes to audit_log.	
DATA & PII	slots.row/col. No personal data.	
EVENTS	slot.moved → socket broadcast to any open editor session.	
EDGE / FAILURE	Drop onto an occupied cell = swap, never overwrite; dropped-outside = no-op; last-write-wins guarded by row version.	

F03 Slot size categories (S / M / L / XL)		
<i>Each slot has a size class that drives price and the physical hardware/space it needs.</i>		
ACTORS	Admin (sets), Pricing engine (reads)	
LIFECYCLE	assign size on slot → size feeds pricing + install checklist → size change re-prices future bookings only	
RULES	Size is an input to the pricing engine (ref WMS-001 §1.3 base price × size). Changing a slot's size does not retroactively re-price a confirmed booking.	
DATA & PII	slots.size enum {S,M,L,XL}. No personal data.	
EVENTS	slot.resized.	
EDGE / FAILURE	Size change while a booking is live is queued to apply at next ended → available.	

F04 Slot status lifecycle management

[route POST /slots/:id/transition](#)

The core state machine every slot obeys — the backbone the other features hang from.

ACTORS	Artist, Staff, Admin, System (timers)
LIFECYCLE	available → reserved (hold timer) → booked (paid) → received → installed → live → ended → available · side states: maintenance, blocked, admin_hold
RULES	Only transitions in the machine are legal; illegal moves rejected with 409 server-side (ref WMS-AUDIT-001 §2.3, SEC-01). reserved auto-expires back to available on hold-timer lapse. Force paths are admin-only (F12).
DATA & PII	slots.state; state changes appended to audit_log. No personal data in the state itself.
EVENTS	slot.transitioned {from,to} → drives carousel, notifications, install queue.
EDGE / FAILURE	Hold-timer expiry race resolved by DB-level guard; a stuck received raises an ops alert after SLA.

F05 Multiple slot types

Standard, Premium, Featured, Workshop, Walk-in, Sponsored — each a pricing and placement policy.

ACTORS	Admin (assigns), Pricing engine (reads)
LIFECYCLE	assign type → type sets price multiplier + eligibility → Sponsored type = 0-fee, admin-granted
RULES	Type multiplier feeds pricing (Premium 1.4×, Featured 1.8×, Workshop 1.5×, Walk-in 1.3×, Sponsored 0×) per WMS-001 §1.1. Walk-in slots are held for day-of bookings; Sponsored requires an admin grant and a funding source record.
DATA & PII	slots.type enum. No personal data.
EVENTS	slot.retyped.
EDGE / FAILURE	Downgrading a Featured slot mid-booking honours the original price for that booking.

F06 Calendar-based availability view

[route GET /slots/availability](#)

Artists see what is bookable, by date, size, type and position, before committing.

ACTORS	Artist (reads), System (computes)
LIFECYCLE	query(date-range, filters) → compute free slots (state=available AND no overlapping hold/booking) → render
RULES	Availability is read from a Redis-cached slot map (TTL 15s) with Postgres fallback (ref WMS-AUDIT-001 §1.2). A slot is 'available' for a date only if no confirmed booking or live hold overlaps that window.
DATA & PII	slots, bookings (dates only). No personal data returned to the client.
EVENTS	none (read path).
EDGE / FAILURE	Cache miss falls back to replica; stale-read window bounded to TTL and reconciled at reservation time.

F07 Multi-slot booking

route **POST /bookings**

One artist books several slots (or a curator books a wall section) in a single transaction.

ACTORS	Artist / Curator
LIFECYCLE	select N slots → reserve all (atomic, all-or-nothing) → single order → pay → all N move to booked, or all roll back
RULES	All-or-nothing: if any slot in the set cannot be held, the whole reservation fails and nothing is charged. Group discounts apply at 5+/10+/full-wall tiers (WMS-001 §1.2). Advisory lock per slot prevents the double-booking race (SEC-02).
DATA & PII	bookings.slot_ids[], artist_id. Personal data: links to an identified artist.
EVENTS	booking.created → invoice, agreement, confirmation graphic, socket update.
EDGE / FAILURE	Partial hold failure → full rollback + released holds; payment timeout → holds expire, slots return to available.

F08 Duration selection (daily to custom)

The artist chooses how long the work hangs — 1 day to a custom span — which drives price.

ACTORS	Artist
LIFECYCLE	pick duration → pricing engine applies per-day discount curve → sets booking end-date → schedules de-install reminder
RULES	Longer durations get lower per-day rates (1d=1.0, 3d=0.95, 1w=0.88, 2w=0.82, 1mo=0.72 per WMS-001 §1.3). End-date sets the live → ended timer and the de-install task.
DATA & PII	bookings.duration/end_date. Linked to artist.
EVENTS	booking.scheduled → de-install reminder job at end-date-24h.
EDGE / FAILURE	Custom span validated against min/max and buffer time between bookings (WMS-001 §2.2).

F09 Artwork upload during booking

route **POST /artworks**

The artist attaches the actual work — image and metadata — as part of booking.

ACTORS	Artist
LIFECYCLE	request presigned URL → direct upload to object store → server validates → attach to booking → artwork in draft → goes public on go-live
RULES	Uploads go direct-to-S3 via presigned URL, never through the API (ref WMS-AUDIT-001 SEC-05). Server validates MIME + magic bytes + size cap and re-encodes to strip metadata/exploits. Artist retains copyright; platform holds a display licence (see F20, IP compliance §6).
DATA & PII	artworks; image may incidentally contain EXIF/GPS — stripped on re-encode (privacy-by-design).
EVENTS	artwork.uploaded → thumbnail + search-index jobs.
EDGE / FAILURE	Disguised/oversized/non-image files rejected; failed re-encode quarantines the file and blocks publish.

F10 Waitlist and queue system

[route POST /waitlist](#)

When the wall is full, artists join a priority queue and are matched when a slot opens.

ACTORS	Artist, System (matcher)
LIFECYCLE	join waitlist (prefs) → queued (priority-ordered) → [slot opens] matched → notified with hold → convert to booking OR expire → re-queue next
RULES	Priority order: Founding Members > repeat > referred > new (WMS-001 §1.2). Match offers a time-boxed hold; on expiry the offer passes to the next in queue.
DATA & PII	waitlist stores name + contact + prefs = personal data → consent + retention apply (§5).
EVENTS	waitlist.matched → notification (email/WhatsApp/SMS per the artist's channel prefs).
EDGE / FAILURE	Notify-channel failure falls back to the next channel; abandoned offers auto-expire.

F11 Add-on pricing system

Optional paid services (NFC, photography, featured listing, content package, spotlight) at booking.

ACTORS	Artist, Pricing engine
LIFECYCLE	select add-ons → priced as flat line-items → added to order total → fulfilled as tasks post-booking
RULES	Add-ons are additive flat fees on top of the slot price (WMS-001 §1.3). Each fulfilled add-on becomes an ops task (e.g. photography → staff task; NFC → inventory assignment).
DATA & PII	bookings.add_ons[]. Linked to artist.
EVENTS	addon.selected → ops task creation on booking confirm.
EDGE / FAILURE	An add-on that cannot be fulfilled (no NFC stock) flags the booking and offers a refund of that line-item only.

F12 Admin force-book & force-release

[Admin · SEC-12 audited](#)

The override valve: an admin can book or release any slot outside the normal flow.

ACTORS	Admin only
LIFECYCLE	force-book: any → booked [admin] · force-release: any → available [admin] + refund trigger
RULES	Admin-only (RBAC matrix, WMS-AUDIT-001 §2.2). Bypasses availability/payment checks by design, but every force action writes actor + before/after to audit_log (SEC-12). Force-release queues the correct policy-based refund.
DATA & PII	slots, audit_log (actor = admin identity).
EVENTS	slot.forced {action} → refund job + affected-artist notification.
EDGE / FAILURE	Force-release of a live artwork raises a de-install task and documents condition first; requires a confirm step (UI/UX fix in WMS-AUDIT-001 §6.3).

Pillar 2 · Exhibition Operations

F13 Installation window scheduling

route POST /checkin/*

The artist picks a 30-minute slot to bring and hang the work; staff get a task.

ACTORS	Artist, Staff, System
LIFECYCLE	booking confirmed → offer windows → artist picks → window reserved → staff task created → check-in (F15)
RULES	Windows respect venue hours and buffer time between bookings (WMS-001 §2.2). One artwork per window; overlaps blocked.
DATA & PII	install_windows linked to booking/artist.
EVENTS	install.scheduled → staff task + reminder to artist.
EDGE / FAILURE	No-show handling: missed window auto-reschedules once, then flags the booking.

F14 Pre-installation checklist generation

Each install auto-generates a checklist so nothing (hardware, NFC, condition photos) is missed.

ACTORS	System (generates), Staff (executes)
LIFECYCLE	install scheduled → generate checklist from slot size/type + add-ons → staff ticks items → 100% required to activate
RULES	Checklist is derived, not manual: size/type/add-ons decide items (hardware, NFC tag, spotlight, condition photos). All items must be complete before received → installed.
DATA & PII	checkins.checklist; condition photos are of artwork, not persons.
EVENTS	checklist.completed → enables go-live.
EDGE / FAILURE	Incomplete checklist blocks activation; a failed item (e.g. damaged frame) opens a condition/damage record.

F15 Staff check-in workflow with QR verification

route POST /checkin/verify

Staff scan the artist's booking QR to verify identity + booking before hanging the work.

ACTORS	Staff, Artist (presents QR), System
LIFECYCLE	scan booking QR → verify signature + booking match → run checklist (F14) → assign & link NFC tag → activate → live
RULES	QR encodes a signed booking token, not raw personal data — verified server-side (privacy-by-design, avoids PII in QR). NFC tag linked here connects the physical piece to its digital record; activation flips installed → live.
DATA & PII	Verifies against bookings/artists; scan event logged. Minimal PII exposure — only booking-scoped.
EVENTS	checkin.verified, nfc.linked, artwork.live.
EDGE / FAILURE	Invalid/expired/tampered QR rejected; mismatch (wrong artwork) blocks and alerts.

F16 Exhibition calendar (master + Gantt)		route GET /calendar
<i>The operational overview: every slot, every booking, overlaps and gaps, on one timeline.</i>		
ACTORS	Staff, Admin	
LIFECYCLE	aggregate all bookings → render master calendar + Gantt bars → surface gaps → suggest waitlist fills	
RULES	Read model over bookings + slots; gaps of 3+ days trigger auto-rotation suggestions from the waitlist (WMS-001 §2.2).	
DATA & PII	Displays artist names to staff/admin only (authorised, need-to-know).	
EVENTS	none (read); acting on a suggestion creates a waitlist offer.	
EDGE / FAILURE	Timezone-safe date math; overlapping bars from buffer time rendered distinctly.	

Pillar 3 · Payments & Billing

F17 Razorpay integration (UPI, cards, net banking)

route [POST /payments/order · /webhooks/razorpay](#)

The money path — collect slot + add-on fees via Razorpay, confirmed by verified webhook.

ACTORS	Artist (pays), Razorpay (PSP), System
LIFECYCLE	create order → artist pays (UPI/card/netbanking) → Razorpay webhook (HMAC-verified) → mark paid in a DB txn → booking booked
RULES	A booking is marked paid ONLY on a signature-verified webhook, never a client callback (ref WMS-AUDIT-001 SEC-03). Card data never touches our servers — Razorpay is PCI-DSS scoped; we store no PAN. Tokenisation per RBI card-storage norms handled by the PSP (§6).
DATA & PII	payments stores order/txn refs + amount, not card data. Linked to artist.
EVENTS	payment . captured → invoice PDF, confirmation, socket, payout ledger entry.
EDGE / FAILURE	Webhook idempotency by event id; late/duplicate webhooks ignored; failed payment leaves booking unpaid and holds expire.

F18 Daily revenue dashboard

route [GET /finance/revenue](#)

Admin's live read on money in — today, this week, by slot and type.

ACTORS	Admin
LIFECYCLE	aggregate captured payments by day → render dashboard → drill into slot/type performance
RULES	Reads settled payments; revenue attributed on capture, not order. Admin-only (RBAC).
DATA & PII	Aggregates; no PII beyond authorised admin view.
EVENTS	none (read).
EDGE / FAILURE	Refunds and chargebacks net against the day they settle, not the sale day.

F19 Monthly P&L auto-generation

route [GET /finance/pnl](#)

Books close themselves: revenue, commissions and costs rolled into a monthly statement.

ACTORS	System (generates), Admin (reviews)
LIFECYCLE	month-end → aggregate revenue (rental, add-ons, commission) – costs (fees, venue share, ops) → generate P&L; → admin review
RULES	Auto-generated from ledger; GST output tax tracked separately (GSTIN 08ABFCA1595D1ZR). Figures are period-attributed and immutable once the month is locked.
DATA & PII	Financial aggregates; no personal data on the statement.
EVENTS	pnl . generated → available for export (PDF/CSV).
EDGE / FAILURE	Late-settling transactions post to the open period; locked periods are adjusted via a documented correction, not overwrite.

F20 Digital exhibition agreement (auto-generated)

IT Act e-sign · route [POST /agreements/:id](#)

Every booking generates a contract the artist e-signs — IP, liability, sales, cancellation.

ACTORS	System (generates), Artist (e-signs)
LIFECYCLE	booking → auto-generate agreement from template + booking facts → artist reviews → e-sign → stored immutably (hash) → accessible to both parties
RULES	Auto-populated with slots, fee, duration, GSTIN. E-signature is valid under the IT Act, 2000 (§6). Terms cover: artist retains copyright + platform display licence; 15% sale commission; 4%+1% resale royalty (ERC-2981); insurance/liability; cancellation refund tiers (WMS-001 §3.2).
DATA & PII	agreements — artist identity + signature timestamp; immutable, hash-sealed.
EVENTS	agreement.signed → unlocks install scheduling.
EDGE / FAILURE	Unsigned agreement blocks go-live; template versioning ensures the artist signs the version shown to them (terms_hash).

Pillar 4 · Visitor & Analytics

F21 QR scan tracking

route POST /scan/:id

Every tap/scan of an artwork is counted — the raw signal behind engagement and demand.

ACTORS	Visitor (anonymous), System
LIFECYCLE	visitor taps NFC / scans QR → resolve artwork → log scan event (async) → increment counters → open artwork page (F22)
RULES	Scans are ingested asynchronously via queue, not synchronous writes, to absorb spikes (WMS-AUDIT-001 §1.3). Anonymous by default — no account required; rate-limited per IP+cookie to keep the demand signal honest (SEC-08).
DATA & PII	scans {artwork_id, ts, source}. Design choice: do not store raw IP against scans; use a rotating hashed key for rate-limiting only → minimises personal data (§5, data minimisation).
EVENTS	artwork.scanned → analytics + demand-signal aggregation.
EDGE / FAILURE	Duplicate rapid scans deduped in a short window; queue backpressure never blocks the page load.

F22 Artwork page with full details

route GET /artworks/:id

The public page a scan opens: image, artist, price, provenance, actions — the heart of the visitor loop.

ACTORS	Visitor (public), Artist (subject)
LIFECYCLE	request by slug/id → server-render (ISR, SEO) → show details + actions (interest, react, share, selfie)
RULES	Public, SEO-optimised (Open Graph + Schema.org VisualArtwork), served via ISR/CDN (WMS-001 §5.4). Artist contact is never exposed — buyer interest routes through the platform (SEC-10).
DATA & PII	Shows artist public profile fields only (name, city, bio) — the artist consents to publication at registration (§5).
EVENTS	artwork.viewed; 'interested' feeds demand-triggered sale.
EDGE / FAILURE	Ended artworks resolve to an archived page, not a 404, preserving links + SEO.

F23 Social sharing (WhatsApp, Instagram, X)

One-tap sharing of an artwork with a pre-filled, branded message — a core viral loop.

ACTORS	Visitor / Artist
LIFECYCLE	tap share → pick channel → pre-filled text + OG image → posted off-platform
RULES	Client-side share intents; the shared link is the public artwork page (F22) with an OG image. No personal data leaves with the share beyond what is already public.
DATA & PII	None beyond public artwork/artist data.
EVENTS	artwork.shared {channel} → share-rate metric (WMS-001 virality).
EDGE / FAILURE	Channel unavailable → copy-link fallback.

F24 Reaction system

route POST /artworks/:id/react

Lightweight, no-signup reactions (fire, heart, palette, gem, wow) on each artwork.

ACTORS	Visitor (anonymous)
LIFECYCLE	tap reaction → increment aggregate → optimistic UI update
RULES	No account needed; rate-limited per IP+cookie to prevent skew (SEC-08). Stored as aggregate counts, not per-person rows → inherently low-PII.
DATA & PII	reactions aggregate counts. No personal data.
EVENTS	artwork.reacted {kind}.
EDGE / FAILURE	Spam/bot bursts throttled and dampened before they reach aggregates.

F25 Selfie upload with branded frame

Consent-gated · route POST /ugc

Visitors post a selfie with the work; a branded frame overlay turns it into shareable UGC.

ACTORS	Visitor, Moderator (staff/admin)
LIFECYCLE	capture/upload → apply branded frame → submit → pending moderation → approved → community gallery (F30) OR rejected
RULES	A selfie is a photograph of an identifiable person = personal data → explicit, informed consent captured at upload for public display, with a clear withdrawal path (§5). Images validated + re-encoded (SEC-05). If the person may be a minor, publication requires verifiable parental consent (§5, children's data).
DATA & PII	ugc — image of a person + optional caption. High-sensitivity; consent-gated.
EVENTS	ugc.submitted → moderation queue.
EDGE / FAILURE	Rejected/withdrawn UGC is deleted from gallery + CDN cache purged.

F26 Walk-in visitor registration

Consent-first · route POST /visitors

An in-venue visitor leaves name + contact to get a summary of everything they scanned.

ACTORS	Visitor
LIFECYCLE	register (name + phone/email + consent) → session links subsequent scans → post-visit summary email → retained per schedule (§8)
RULES	Collection is consent-first: purpose (visit summary + optional future invites) stated at the point of collection; marketing consent is a separate opt-in, not bundled (§5). Minimal fields only.
DATA & PII	visitors — name + contact = personal data. Consent + retention + rights apply.
EVENTS	visitor.registered → summary email job.
EDGE / FAILURE	No consent = no registration; contact validation before store.

Pillar 5 · Discovery & Engagement

F27 Live carousel on artwalllabs.com

[route GET /slots + WS](#)

The homepage shows everything currently on the wall, updating as works go live/come down.

ACTORS	Visitor (public), System
LIFECYCLE	artwork goes live → appears in carousel → artwork ends → removed → real-time via socket
RULES	Driven by <code>slot.transitioned</code> events over Socket.IO + Redis fan-out (WMS-AUDIT-001 §1.1), not per-client polling. Shows only public data.
DATA & PII	Public artwork + artist public fields only.
EVENTS	consumes <code>artwork.live</code> / <code>artwork.ended</code> .
EDGE / FAILURE	Socket drop → client falls back to periodic REST refresh; cold load served from ISR cache.

F28 Full-text search engine

[route GET /search](#)

Search across artists, titles, mediums, cities and statements, with filters.

ACTORS	Visitor (public), System
LIFECYCLE	index artworks/artists on publish → query → ranked results → filters (medium, date, price, location)
RULES	Async indexing to Meilisearch on publish (WMS-AUDIT-001 §1.1); index holds only public fields. Query strings validated; no PII in query logs.
DATA & PII	Indexes public data only. Search logs avoid personal identifiers.
EVENTS	<code>index.updated</code> on artwork publish/unpublish.
EDGE / FAILURE	Index lag bounded; a just-published piece appears within the indexing SLA; empty results give a directed empty state (UI/UX §6.1).

F29 Booking confirmation shareable graphic

On booking, the artist gets a branded 'I'm exhibiting at The Wall' graphic to post.

ACTORS	Artist, System
LIFECYCLE	booking confirmed → render branded graphic (slots, dates, venue) → artist downloads/shares
RULES	Generated from booking facts + Founding Member status; contains only the artist's own booking info. A viral loop (WMS-001 §5.3).
DATA & PII	Artist's own booking data, shared at the artist's initiative.
EVENTS	<code>confirmation.generated</code> .
EDGE / FAILURE	Render failure retried async; share is never on the critical booking path.

F30 Community gallery (UGC) Moderated · route /ugc, /ugc/:id/moderate	
The moderated public wall of visitor selfies and posts — social proof and reach.	
ACTORS	Visitor (contributes), Moderator, Public (views)
LIFECYCLE	UGC submitted (F25) → pending → [moderator] approve/hide → public gallery → withdrawable by contributor
RULES	Only approved UGC is public (WMS-001 §5.2). Moderation guards against harmful/infringing content. Contributors can withdraw consent → item removed + CDN purged (§5 rights).
DATA & PII	ugc — images of identifiable people; consent + moderation + retention govern it.
EVENTS	ugc.approved / ugc.removed.
EDGE / FAILURE	Reported content is hidden pending review; takedown honoured promptly.

Pillar 6 · Artist Management

F31 Artist registration flow

DPDP notice+consent · route
POST /auth/register

How an artist joins — profile, contact, medium, and (before first sale) DigiLocker identity.

ACTORS	Artist, System, DigiLocker (verification)
LIFECYCLE	register (fields + consent + notice) → account active + Founding Member → optional DigiLocker verify → verified (required before first payout/sale)
RULES	At sign-up the artist is shown a DPDP-compliant notice and gives itemised consent (account vs marketing) (§5). DigiLocker identity is required before first sale/payout for provenance + KYC-grade trust (WMS-001 §6.1). Public profile publication is consented.
DATA & PII	users/artists — name, email, phone, city, medium, bio = personal data. Full DPDP lifecycle applies (notice, consent, rights, retention).
EVENTS	artist.registered, artist.verified.
EDGE / FAILURE	Duplicate email/phone guarded; unverified artists can exhibit but not receive payouts; consent withdrawal triggers the erasure workflow (§5/§8).

F32 Post-exhibition feedback survey

After a show ends, the artist rates the experience (stars + NPS + notes) to close the loop.

ACTORS	Artist, System
LIFECYCLE	exhibition ends → survey invite → artist submits rating/NPS/notes → feeds improvement loop + satisfaction metric
RULES	Voluntary; tied to a completed booking. Free-text is treated as potentially personal and stored under the same retention rules (§8).
DATA & PII	feedback linked to booking/artist; free-text may contain personal data.
EVENTS	feedback.submitted → satisfaction/NPS aggregation.
EDGE / FAILURE	One response per booking; reminders capped to avoid nuisance (aligns with consent/nuisance norms).

SECTION 3

Production-Grade Engineering

The controls that make the difference between a demo and a system real artists and money depend on. These sit above the feature set and apply to all of it.

3.1 Environments & release

Concern	Standard
Environments	local → staging (prod-like, seeded) → production; no shared DBs across envs
CI	lint + typecheck + unit + integration on every PR; block on red; secret-scan
CD	trunk-based, tagged releases, blue-green or rolling deploy, one-command rollback
Migrations	versioned, forward-only, reviewed; expand-then-contract for zero-downtime schema change
Config/secrets	12-factor env config; secrets in a manager (not in code/bundle) — SEC-09
Feature flags	risky features (force-release, takeover, payouts) behind flags for staged rollout

3.2 Reliability & scale (to 10,000 users)

- **Stateless API** behind a load balancer; scale pods horizontally — no server-side session affinity.
- **Data tier**: Postgres primary + read replica, PgBouncer pooling; Redis for cache/sessions/rate-limits; queue workers scale independently (WMS-AUDIT-001 §1).
- **Idempotency** on all money and booking writes (order ids, webhook event ids) to survive retries.
- **Backups & DR**: automated daily backups + point-in-time recovery; documented restore drill; defined RPO/RTO.
- **Graceful degradation**: chain mint, search index and emails are off the critical path — the wall keeps booking if any is down.

3.3 Observability

- **Structured logs** with correlation ids across API → queue → webhook; **no PII in logs** (SEC-10/§5).
- **Metrics & SLOs**: availability, booking success rate, payment-webhook lag, scan-ingest lag; alert on burn.
- **Tracing** on the booking→payment→confirmation path; **audit_log** for every override and money movement.
- **Error tracking** with release tagging so regressions are tied to a deploy.

3.4 Testing quality gates

Layer	What it proves
Unit	Pricing engine, state-machine transitions, validators are correct in isolation
Integration	Booking↔payment↔agreement flow, webhook verification, refund math
Concurrency/load	No double-book under 50 parallel bookings on one slot (SEC-02); scan-spike ingest
Security	IDOR suite, authz on every write, upload validation, injection/XSS (SEC-01/04/05/06/07)
Accessibility	Keyboard-only + screen-reader pass; WCAG 2.1 AA (WMS-AUDIT-001 §6.2)
E2E	Golden paths per role (visitor scan→share, artist book→sign, admin check-in→live)

SECTION 4

Security Engineering & Threat Model

Summarised here and specified in full in the audit pack (WMS-AUDIT-001 §5). The threat model asks, per asset, who could abuse it and what stops them.

Asset	Primary threat	Control
Admin actions	Privilege escalation via client	Server-side authorize(), default-deny, audited overrides (SEC-01/12)
Slot inventory	Double-booking race	Advisory lock + reservation hold + unique constraint (SEC-02)
Money	Forged 'paid' confirmation	HMAC-verified webhook only; idempotent; no client-trust (SEC-03)
Artist data	IDOR across accounts	Ownership checks on every own-scoped route (SEC-04)
Uploads	Malware / disguised files	Presigned S3, MIME+magic-byte, size cap, re-encode (SEC-05)
Inputs	SQLi / XSS	Parameterised queries, boundary validation (Zod), output escaping, CSP (SEC-06/07)
Signals	Scan/reaction spam	Rate-limit per IP+cookie, dedupe, bot detection (SEC-08)
Secrets	Leak via client/logs	Secrets manager, none in bundle, no PII in logs (SEC-09/10)
Sessions	Token theft	httpOnly+Secure cookies, short TTL, Redis denylist, 2FA staff/admin (SEC-11/14)

Security is continuous: dependency scanning, periodic penetration testing before major launches, and a documented incident-response runbook that plugs directly into the DPDP breach-notification workflow (§5.6).

SECTION 5

DPDP Act 2023 & Rules 2025 Compliance

India's Digital Personal Data Protection Act, 2023 received assent on 11 August 2023; the DPDP Rules, 2025 were notified on 13–14 November 2025 and the Data Protection Board of India is operational. Obligations phase in, with the substantive compliance deadline landing 13 May 2027. Artwall Labs processes personal data of identifiable artists and visitors and is therefore a **Data Fiduciary**; this section maps each obligation to the WMS.

5.1 Roles & scope

DPDP concept	In the WMS
Data Fiduciary	Artwall Labs Pvt Ltd — decides purpose & means of processing
Data Principal	Artists (F31), walk-in visitors (F26), waitlist entrants (F10), UGC contributors (F25)
Data Processor	Sub-processors acting on our instructions: Razorpay, cloud/storage, email/WhatsApp, search, analytics
Personal data held	Name, email, phone, city, bio, booking history, selfies (UGC), feedback text
Not stored by us	Card/PAN data (Razorpay-scoped, PCI); raw IP against scans (minimised — F21)

5.2 Notice & consent

- Consent must be **free, specific, informed, unconditional and unambiguous** with a clear affirmative action — collected at each point of collection (F26 visitor, F31 artist, F25 UGC, F10 waitlist).
- A **plain-language notice** accompanies every consent: what data, why, for how long, which rights, and how to withdraw or complain — available in English and, where feasible, other Indian languages per the Rules.
- Purpose limitation & no bundling**: account/booking consent is separate from marketing consent; a checkbox for one is never a checkbox for the other.
- Withdrawal is as easy as giving** consent — a one-tap control; withdrawal stops further processing and triggers deletion where nothing else requires retention (§8).
- A **Consent Manager** record ties every processing activity to the consent that authorises it, so consent is auditable end-to-end.

5.3 Data Principal rights (build these as features)

Right	How the WMS serves it
Access & summary	Self-service export of the artist/visitor's own data from their dashboard
Correction & completion	Editable profile fields; correction request workflow for the rest
Erasure	'Delete my data' flow → erase or irreversibly anonymise, except records law requires we keep (tax, contracts)
Grievance redressal	In-product grievance channel to a named contact; time-bound response
Nominate	Ability to nominate another to exercise rights (per the Act) captured in profile settings
Withdraw consent	One-tap withdrawal per purpose (§5.2)

5.4 Children's data (critical for an open art platform)

- The DPDP Act treats anyone **under 18** as a child and requires **verifiable parental/guardian consent** before processing their personal data.
- It **prohibits tracking, behavioural monitoring and targeted advertising** directed at children.

- WMS impact: registration (F31), walk-in (F26) and especially **selfie UGC (F25)** must handle the possibility of a minor. Design: age self-declaration + a parental-consent path before any child's personal data is published; no behavioural profiling of visitors regardless of age (reinforces the F21 minimisation choice).

5.5 Security safeguards & processors

- 'Reasonable security safeguards' are a statutory duty — encryption in transit and at rest, access control, and the full Section 4 control set discharge this.
- Every **Data Processor** (Razorpay, cloud, email/WhatsApp, search, analytics) is bound by a **written data-processing agreement** restricting them to our instructions.
- **Privacy-by-design** is already visible in the build: EXIF stripped on upload (F09), no raw IP on scans (F21), signed tokens not PII in QR (F15), artist contact never exposed (F22).

5.6 Breach notification

- On a personal-data breach, the WMS incident runbook notifies the **Data Protection Board** and **affected Data Principals** without undue delay, in the form the Rules prescribe.
- Detection is automated (Section 3 observability); an incident-response team, escalation path and comms templates are pre-staged so notification is fast, not improvised.

5.7 Significant Data Fiduciary (forward-looking)

If growth causes the Board to classify Artwall Labs as a Significant Data Fiduciary, additional duties attach: appointing a Data Protection Officer based in India, a periodic Data Protection Impact Assessment, and independent audits. The architecture (audit_log, consent records, retention schedule) is built so these become reporting exercises, not re-engineering.

Penalties for non-compliance run up to ₹250 crore for failure to take reasonable security safeguards — which is why the security and consent controls above are treated as launch-blocking, not backlog.

SECTION 6

Other Regulatory Compliance

6.1 GST & tax

- GST-compliant tax invoices auto-generated on every booking/add-on/sale under **GSTIN 08ABFCA1595D1ZR** (F17/F19), with correct HSN/SAC, place of supply and tax split.
- Output tax tracked separately in the P&L; (F19); TDS/TCS handled on artist payouts where applicable.
- Sale commission and resale royalty flows invoiced correctly; provenance/royalty is a contractual right, not a tradable financial instrument.

6.2 IT Act, 2000 — e-signature & intermediary

- The auto-generated exhibition agreement (F20) is e-signed; electronic records and signatures are legally valid under the **IT Act, 2000**, with the signed version hash-sealed for evidentiary integrity.
- As a platform hosting user content (UGC F25/F30, artist uploads F09), Artwall follows intermediary due-diligence norms: clear terms, a grievance officer, and prompt takedown of unlawful/infringing content.

6.3 Payments — RBI & PCI (via Razorpay)

- Razorpay is the **PCI-DSS**-scoped payment aggregator; the WMS never stores card/PAN data (SEC-03/§5).
- Card-on-file **tokenisation** per RBI norms is handled by the PSP; we hold only tokens/refs.
- Refunds, cancellation tiers and settlement follow RBI payment-aggregator guidelines and are reflected in the agreement (F20) and refund logic (F12).

6.4 Consumer protection & e-commerce

- Under the **Consumer Protection Act, 2019** and e-commerce rules: transparent pricing (all fees + GST shown before pay — F07/F11), clear cancellation/refund terms (F20), and an accessible grievance mechanism.
- No dark patterns: consent and marketing opt-ins are unbundled and reversible (§5.2), aligning with CCPA/dark-pattern guidance.

6.5 Intellectual property

- Artists **retain copyright**; the agreement (F20) grants Artwall a limited licence to display and market the work — never an assignment.
- Uploaded works and UGC are screened at moderation (F14/F30) for infringing material; a notice-and-takedown path handles claims.
- Resale royalty (4% artist + 1% platform) is enforced via ERC-2981 on Polygon (WMS-001 §3.2) as a contractual entitlement.

6.6 Accessibility

The public surfaces target WCAG 2.1 AA (WMS-AUDIT-001 §6.2), consistent with the spirit of the Rights of Persons with Disabilities Act, 2016 and GIGW guidance for accessible digital services — keyboard operability, contrast, alt text and reduced-motion are quality gates, not afterthoughts.

SECTION 7

Feature × Compliance Traceability

Which regulated obligation each personal-data or money-touching feature triggers. Features that touch only non-personal config are omitted.

Feature	DPDP (personal data)	RBI/PCI (payments)	GST/tax	IP / IT Act
F07 Multi-slot booking	✓	✓		
F09 Artwork upload	✓			✓
F10 Waitlist	✓			
F17 Razorpay payments	✓	✓	✓	
F19 Monthly P&L;			✓	
F20 Exhibition agreement	✓	✓	✓	✓
F21 QR scan tracking	✓			
F22 Artwork page	✓			✓
F25 Selfie UGC	✓			✓
F26 Walk-in registration	✓			
F30 Community gallery	✓			✓
F31 Artist registration	✓			
F32 Feedback survey	✓			

Reading: F20 (the agreement) is the densest node — it is simultaneously a personal-data record, a payment term, a tax document and an IP licence, which is why it is auto-generated, versioned and hash-sealed.

SECTION 8

Data Retention & Lifecycle Schedule

DPDP requires that personal data not be kept past its purpose. Retention is defined per data class, balancing the Act's minimisation duty against tax/contract record-keeping law.

Data class	Retain while / for	On expiry or withdrawal
Artist account/profile	Account active + purpose valid	Erase or anonymise on account closure (keep tax/contract records)
Booking & agreement	Statutory contract/tax retention period	Retain minimally for legal record; not used for other purposes
Payment records	As required by tax/PSP/RBI rules	Retain per law; card data never held by us
Walk-in visitor	Until visit-summary purpose served / consent window	Delete on expiry or on withdrawal (F26)
Waitlist	Until matched or the entrant leaves the queue	Delete on exit or withdrawal (F10)
Selfie / UGC	While consent stands & item is public	Delete + CDN purge on withdrawal/rejection (F25/F30)
Scan/reaction signals	Aggregated; raw events short-lived	Aggregate kept (non-personal); raw events rolled off quickly (F21/F24)

Data class	Retain while / for	On expiry or withdrawal
Feedback text	With the related booking record	Rolled off with the booking's retention window (F32)
Audit log	Long-lived for security/accountability	Append-only; access-controlled; not repurposed

This specification is a living document. Regulatory positions — especially the phased DPDP Rules timelines up to 13 May 2027 — should be reviewed with counsel before launch and re-checked each quarter. References throughout point to AWL/PRODUCT/2026/WMS-001 (feature plan) and AWL/ENG/2026/WMS-AUDIT-001 (engineering & audit pack).